SENTINEL · ESSECKATHON TRACK 01 · FINTECH SECURITY

Conformite

Chaque decision de paiement d'agent devient une preuve inviolable, horodatee et rejouable sur Avalanche. L'audit n'est plus declaratif, il est verifiable on-chain.

SentinelL1 Live | chainId 99999 | token SEC | 2026-10-11

Un controle = `DecisionRecorded` **Un refus** = `ThreatFlagged` **Une autorisation** = `VisaGranted` (visa a usage unique)

DORA Digital Operational Resilience Act

- Journal d'incidents inviolable : chaque block ou flag est un evenement on-chain date, une piste d'audit non repudiable (journalisation et detection des incidents TIC).
- Detection et reponse : le garde detecte (7 couches + IA) et repond (block / flag / escalade) en moins d'1 ms (heuristiques) ou environ 3 s (fusion IA) ; un incident DORA est ouvert automatiquement au refus.
- Resilience : repli local si la chaine est injoignable (le verdict tient), et le paiement ne passe jamais sans visa valide (fail-closed via GuardedVault).
- Reporting : metriques exportables (taux de detection, faux positifs, temps de detection et de reponse, nombre d'incidents) pour le registre d'incidents.

MICA Markets in Crypto-Assets

- Tracabilite des transferts : emetteur, beneficiaire, montant, verdict et motif inscrits on-chain.
- Controle du beneficiaire : registre de menaces on-chain et allowlist des contreparties, refus des adresses signalees (address poisoning, marchand fantome).
- Gouvernance : decision par smart contract (AuthorityRegistry), autorites revocables, flags contestables (clearThreat, le droit de recours).

AML / CFT Travel Rule

- Qui paie qui, combien, pourquoi : attache a chaque transaction (elements Travel Rule).
- Detection de schemas : structuring (montant juste sous le plafond), velocite, beneficiaire recemment modifie, honeypot ou contrat non verifie.
- Registre des adresses a risque : partage on-chain, la deuxieme tentative vers une adresse flaguee est refusee d'office.

KYB SOUVERAIN

SOUVERAIN know your beneficiary

Couche opt-in (GUARD_KYB=on) qui verifie le beneficiaire contre le registre officiel des entreprises de l'Etat (API Recherche d'entreprises, data.gouv.fr / DINUM). Entreprise active et correspondante : preuve officielle attachee a la decision (SIREN + etat). Beneficiaire radie, introuvable ou nom non concordant : signal de risque et escalade humaine. Verification par une source tierce officielle, loggee et rejouable (exigence DORA sur les tiers), jamais declarative. Si le registre est indisponible, aucun paiement n'est debloque pour autant (fail-closed via les autres couches).

AI ACT Reglement IA de l'Union europeenne

- Transparence et explicabilite : chaque decision est explicable (signaux cites, poids, formule OU bruite, seuils affiches).
- Surveillance humaine : la zone de doute (30 a 70) est escaladee a un humain avant tout paiement ; sa decision est tracee.
- Robustesse : banc de tests honnete (detection 100 %, evasion 814 essais, faux positifs 0 %) et un adversaire adaptatif reel (0 bypass).
- Journalisation : enregistrement automatique des decisions (logs + on-chain) sur toute la duree de vie.
- Gestion du risque : pas d'allow devine sans preuve, plancher humain quand l'IA est indisponible.

SEUILS DE DECISION · RECOMMANDATION KPMG

Confiance ≥ 70
Visa delivre, le paiement passe

30 a 70
Escalade a un humain avant tout paiement

Confiance < 30
Refus et flag de l'adresse au registre

Seuils resserres automatiquement quand le montant approche le plafond du mandat.

PREUVES ON-CHAIN · VERIFIABLES PAR LE JURY

Chaine `SentinelL1 (chainId 99999)` **AuthorityRegistry** `0x7A7e…bcb6` **GuardedVault** `0xc7de…C7c0`

Explorer `https://explorer.petroi.fr`